cloudmed™

Report on Cloudmed's (formerly Triage Consulting Group) Description of its Hospital and Physician Comprehensive Payment Review System and the Suitability of the Design and Operating Effectiveness of Its Controls Relevant to Security and Confidentiality

SOC for Service Organizations: SOC 2 Type II

For the Period April 1, 2020 to March 31, 2021

This report is intended solely for use by the management of Cloudmed, user entities of Cloudmed's services, and other parties who have sufficient knowledge and understanding of Cloudmed's services covered by this report (each referred to herein as a "specified user").

If report recipient is not a specified user (herein referred to as a "non-specified user"), use of this report is the non-specified user's sole responsibility and at the non-specified user's sole and exclusive risk. Non-specified users may not rely on this report and do not acquire any rights against Behunin & Associates, P.C. as a result of such access. Further, Behunin & Associates, P.C. does not assume any duties or obligations to any non-specified user who obtains this report and/or has access to it.

Unauthorized use, reproduction or distribution of this report, in whole or in part, is strictly prohibited.

Table of Contents

Section 1: Independent Service Auditor's Report 1

Independent Service Auditor's Report 2

Section 2: Management Assertion 5

Cloudmed's Assertion 6

Section 3: Cloudmed's Decription of the System 7

Overview of Operations 8

Description of Services Provided 8

Service Commitments and System Requirements 10

System Boundaries 10

Components of the System Used to Provide the Service 10

Relevant Aspects of the Control Environment, Risk Assessment Process, Monitoring Controls and Information and Communication 13

System Incidents During the Period 22

Disclosure of Significant System Changes 22

Subservice Organizations 22

Complimentary User Entity Controls 22

Section 4: Trust Services Criteria, Related Controls, Test of Controls, and Results 24

Section 5: Other Information Provided by Management 52

Section 1: Independent Service Auditor’s Report

B&A Behunin & Associates

Independent Service Auditor's Report

To the Management of Cloudmed (formerly Triage Consulting Group)

Scope

We have examined Cloudmed's (formerly Triage Consulting Group; herein Cloudmed) accompanying description of its Comprehensive Payment Review Service found in Section 3 titled "Cloudmed's Description of the System" throughout the period April 1, 2020 to March 31, 2021 (description) based on the criteria for a description of a service organization's system set forth in DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (AICPA, Description Criteria), (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period April 1, 2020 to March 31, 2021, to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality categories (applicable trust services criteria) set forth in TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria) that are applicable to Cloudmed.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents Cloudmed's controls, the applicable trust services criteria, and the types of complementary user entity controls assumed in the design of Cloudmed's controls.

Service Organization's Responsibilities

Cloudmed is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved. In Section 2, Cloudmed has provided the accompanying assertion titled Cloudmed's Assertion (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. Cloudmed is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Evaluating the overall presentation of the description.
- Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Test of Controls

The specific controls we tested, and the nature, timing, and results of those tests are listed in Section 4 of this report.

Opinion

In our opinion, in all material respects:

- The description presents Cloudmed's Comprehensive Payment Review Service that was designed and implemented throughout the period April 1, 2020 to March 31, 2021 in accordance with the description criteria.
- The controls stated in the description were suitably designed throughout the period April 1, 2020 to March 31, 2021 to provide reasonable assurance that Cloudmed's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the user entity applied the complementary controls assumed in the design of Cloudmed's controls throughout that period.
- The controls stated in the description operated effectively throughout the period April 1, 2020 to March 31, 2021 to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary user entity controls assumed in the design of Cloudmed's controls operated

effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4 is intended solely for the information and use of Cloudmed; user entities of Cloudmed 's Comprehensive Payment Review Service during some or all of the period April 1, 2020 to March 31, 2021, business partners of Cloudmed subject to risks arising from interactions with the Comprehensive Payment Review Service during, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization.
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties.
- Internal control and its limitations.
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.
- The applicable trust services criteria.
- The risks that may threaten the achievement of the service organization’s service commitments and system requirements and how controls address those risks.

This report is not intended to be and should not be used by anyone other than these specified parties.

Behunin & Associates, P.C.

Collegeville, PA

August 19, 2021

Section 2: Management’s Assertion

cloudmed™

Cloudmed's Management Assertion

We have prepared the accompanying description of Cloudmed's Comprehensive Payment Review Service found in section 3 titled Cloudmed's Description of the System throughout the period April 1, 2020 to March 31, 2021 (description) based on the criteria for a description of a service organization's system set forth in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*), (description criteria). The description is intended to provide report users with information about the Hospital and Physician Payment Review Services that may be useful when assessing the risks arising from interactions with Cloudmed's system, particularly information about system controls that Cloudmed has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality principles (applicable trust services criteria) set forth in TSP section 100, *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria*).

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Cloudmed, to achieve Cloudmed's service commitments and system requirements based on the applicable trust services criteria. The description presents the service organization's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of the service organization's controls.

We confirm, to the best of our knowledge and belief, that:

a. The description presents Cloudmed's Comprehensive Payment Review Service that was designed and implemented throughout the period April 1, 2020 to March 31, 2021 in accordance with the description criteria.

b. The controls stated in the description were suitably designed throughout the period April 1, 2020, to March 31, 2021 to provide reasonable assurance Cloudmed's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the user entities applied the complementary controls assumed in the design of Cloudmed's controls throughout that period.

c. The controls stated in the description operated effectively throughout the period April 1, 2020, to March 31, 2021 to provide reasonable assurance that Cloudmed's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary user entity controls assumed in the design of Cloudmed's controls operated effectively throughout that period.

Cloudmed Management

Section 3: Cloudmed’s Description of the System

Overview of Operations

Company Background

Founded in 1994, as Triage Consulting Group, Cloudmed is one of the nation's leading hospital and physician revenue enhancement service providers. With over 600 consultants working from its offices in San Francisco and Sacramento, California, Atlanta, Georgia, and Cherry Hill, New Jersey, Cloudmed specializes in hospital and physician payment review and recovery, revenue cycle improvement, and contract analytics. Cloudmed's reviews are performed nationwide and encompass managed care, Medicare, Medicaid, TRICARE, VA, Workers' Compensation, ERISA, Silent PPO and other payers whose payment terms are subject to underpayment, denial, and revenue integrity risk. Since inception, Cloudmed has recovered over $4 billion on behalf of over 800 hospitals and practice groups, and currently collects over $650 million per year for its clients. In October 2020, Triage Consulting Group merged with Revint, Inc. to form Cloudmed. System changes related to the merger, where applicable, are detailed below.

More information on the combined organization can be found at http://www.cloudmed.com.

Description of Services Provided

Hospital Commercial Underpayment Review

Cloudmed's Comprehensive Payment Review is a single solution that leverages proprietary software, expertly developed technologies, and trained Consultants to review claim reimbursement and revenue integrity at all stages of the Revenue Cycle.

With over 25 years of experience, and a large client base, Cloudmed has amassed institutional knowledge analyzing payer agreement terms and reimbursement structures, understanding clinical code-sets, and refining proprietary software and advanced technologies to maximize results. Our Commercial Payer Review includes a deep dive audit across a myriad of key underpayment drivers.

Silent PPO Review

Strategic payer negotiations, in exchange for channeled business, is a cornerstone of hospital reimbursement. In the absence of a direct contract, non-contracted payers may attempt to reduce their liability by inappropriately accessing PPO contract rates when neither a valid contractual relationship nor explicit and transparent access to the contract agreement exists. Cloudmed's Silent PPO Review identifies and recovers underpayments from non-contracted payers who inappropriately access discounted rates. In silent PPO scenarios, it can be difficult to trace back what was paid, and as a result, the discounted payment is often accepted. Cloudmed conducts in-depth research to identify instances of inappropriate discount access and recovers the reasonable and customary amount due. Based on the silent PPO trends observed at your organization, we provide education on how to identify inappropriate network access, and when applicable, best practice contract language to prevent silent PPO access.

Hospital Government Underpayment Review

Medicare Review

Cloudmed's suite of audit technologies detects billing, coding, charging, coverage, and administrative inconsistencies which result in reduced payment. Certified coders and Medicare reimbursement experts excel at providing claim-level recommendations that are supported by the medical record, compliant, and even tailored to the specific Medicare Contractor involved. Root cause feedback, which is grounded in CMS regulations, billing and coding rules, and supplemental information requirements, is reported back to clients to aid in education, and to prevent future cash loss.

In addition to reviewing Medicare Fee For Service claims, Cloudmed leverages its knowledge and tools to review all payers who align with Medicare, or Medicare-like payment methodology: Medicare

Advantage, CHAMPUS/TRICARE, Veteran's Administration, etc.

Medicaid Review

Cloudmed works with over 800 hospitals and health systems nationwide and we have extensive experience with nearly every state Medicaid program in the country. A dedicated team of consultants reviews every claim to identify gaps in Medicaid reimbursement and then works to recover those dollars and provide your team with a root-cause analysis to facilitate prevention moving forward. Additionally, our team of state-specific Medicaid experts consistently monitors, reviews, and offers feedback regarding state policies and fee schedule changes that may impact your hospital's reimbursement.

Workers' Compensation

Cloudmed entered the workers' compensation early-out and outsourcing space in 2012, and has partnered with providers to maximize the yield and minimize the hassle associated with this population; we tailor every engagement specifically to each client, which includes academic, specialty (designated cancer hospital, inpatient rehabilitation, psychiatric, etc.), and multi-facility hospital systems. While we have the capability to assist with nearly all facets of the revenue cycle, calculating accurate expected reimbursement is fundamental to ensuring the correct payment is received.

Coding and Revenue Integrity Services

Cloudmed's suite of audit technologies provides revenue assurance for the myriad services providers deliver. Across inpatient coding, DRG accuracy, outpatient coding, charge capture, pharmaceutical billing, and CDM alignment, we deploy a comprehensive audit for each, pairing refined rules engines and adaptable machine learning algorithms, with expert guided research to deliver missed revenue. As the industry leading safety net, we have the expertise, technology, and service oriented approach to ensure you receive accurate reimbursement for the care you provide with minimum resource investment.

Physician Underpayment Review

Cloudmed's Physician Review Services (TPRS) provides a risk-free payment audit and recovery service for large healthcare providers and practice plans. Our customized solution identifies consistent sources of underpayment, includes follow up and collection on underpaid accounts, and provides clients with the data needed to favorably renegotiate contracts to help plug the leaks going forward.

Litigation Support

Cloudmed's consultants have extensive knowledge and experience in claims reimbursement issues and claims payment processes, including but not limited to: pricing claims (based off the UB-04 or from data files) according to negotiated agreements or government fee schedules, identifying the root cause for the denial or underpayment, and recovering the amounts not paid. This in-depth expertise allows Cloudmed Principals, Directors and Senior Managers to serve as Expert Witnesses.

When serving in the Expert Witness role, Cloudmed provides a thorough, independent, objective report summarizing the claims at stake, the underlying issues, the supporting documentation, the damages owed (including interest, as appropriate), and the categorization of issues to streamline the execution of the case in trial. In the process of completing this report, Cloudmed provides various case support services, including but not limited to:

- Claim set analysis (pricing, payment verification and analysis, interest calculations, etc.)
- Financial modeling & settlement estimates
- Discovery & per-claim document pull (if necessary and requested)

Consulting Services

Cloudmed provides a variety of consulting and advisory services related to reimbursement, managed care contracts, and revenue cycle improvement. Some areas of expertise are listed below:

- Contract Analysis
- Denial Capture and Analysis
- Data and Spreadsheet Management
- JOC/Payer Meeting Support
- Education & Training

Denials Management

The unfortunate reality for all healthcare providers is that claim denials represent an administrative headache and a major source of revenue leakage annually. As such, the recovery and prevention of denials is critical for maintaining the financial health of your organization. While many providers already have policies and procedures in place to prevent and overturn denials, Cloudmed's denials department focuses on the most complex and difficult to collect denials that either slip through the cracks or that your team simply does not have the time for. Using in-house clinical staff, certified coders, and Denials Consultants, Cloudmed reviews medical records, payer policies, state laws and regulations and legal resources to overturn and recover the lost revenue associated with these denials. Throughout the process we provide ongoing feedback and root-case analysis to help your team identify, recover, and prevent these denials moving forward.

Service Commitments and System Requirements

Cloudmed designs its processes and procedures related to its Comprehensive Payment Review Service based on the service commitments outlined in the Service Agreements and Business Associate Agreements entered into with its client. Those agreements require Cloudmed to maintain security and confidentiality for all systems within the Cloudmed environment used for processing and storing the sensitive information, including Protected Health Information (PHI), provided to us by our clients. Those requirements, in turn, are based on the security and privacy requirements of the Health Insurance Portability and Accountability Act, as amended, including related regulations. Cloudmed has compliance and operational procedures in place to help ensure that the security and confidentiality commitments for our customer's data can be met.

System Boundaries

The scope of this report covers the networking and server environment that is controlled by Cloudmed to provide secure storage, access and transmission of data to authorized users of the data at Cloudmed. The systems that make up this scope include Windows-based secure access, secure email transfer, VPN connectivity, encryption and access control and logging software that make up this infrastructure. It also includes Cloudmed's Common Data Platform (CDP) application which is utilized to access databases containing client-provided data for review. The scope of this SOC 2 attestation is this infrastructure and software as well as the management practices, system administration and support activities required for the system to operate effectively. There are no subservice organizations that impact this report.

Components of the System Used to Provide the Service

Infrastructure

Cloudmed operates secure networks in all its offices. Cloudmed's offices are located in multi-floor office buildings, with 24-hour security and cameras. The server room in each office is controlled by

limited-access badge entry and has an alarm if the door remains open for an extended period of time. Cameras are also fixed on data center entry points. Further, there are environmental monitors in the server rooms that detect door activity, smoke, water, humidity, and temperature, and send email alerts when appropriate.

Cloudmed's infrastructure is built using hardware from vendors such as Dell, Fortinet, Cisco, IBM and NetApp, and software from vendors such as Microsoft and VMware. In addition, Cloudmed utilizes a variety of tools and software to monitor systems and ensure uptime, failover and disaster recovery. Cloudmed's infrastructure is built for high availability, as multiple servers, firewalls, switches, and backup solutions provide redundancy at a variety of levels within the system.

Cloudmed employs VMware and SAN mirroring across its San Francisco (where Sacramento data is housed) and Atlanta server rooms to ensure continuity and uptime for these systems which support the hospital review services. This technology allows a single local server and/or multiple hard drives to fail without interruption to operations, and for certain functions to fail over to another office (San Francisco to Atlanta, Atlanta to San Francisco) in case of a major incident. Data in each office is backed up locally on tier 1 storage every four hours, and across offices on a nightly basis to tier 2 storage. In case of a local disaster, the cross-office data backup becomes the primary copy. The New Jersey office, which supports the physician review services work, leverages the same technologies with the exception that nightly tier 2 offsite backups are performed to a domestic third-party business continuity partner. Further, Cloudmed divides its work with clients into project teams, which self-reliantly work in a workgroup/pod environment that could continue to function in the absence of major IT systems.

All Cloudmed servers are installed behind redundant firewalls configured for high availability and minimal vulnerability. Server operating systems in use include Linux and Windows Server releases which are supported by manufacturers and approved by Cloudmed management. Operating system and anti-virus software updates are installed on a regular basis.

Cloudmed has deployed Unified Threat Management firewalls that control inbound and outbound access to its networks, including VPN configurations for secure transmission of customer data. The firewalls also provide intrusion detection and real-time logging.

Secure network connections and protocols are responsible for the encrypted transfer of protected health information (PHI) outside the network. Internet standards such as VPN tunnels, HTTPS and SFTP are employed to prevent third-party interception of sensitive data.

All Cloudmed laptops are protected by AES-256 full disk encryption and require dual-factor authentication (password and physical token). Windows Updates are routinely deployed to laptops and desktops, as are updates to Cloudmed's endpoint security solution.

Software

Cloudmed utilizes the Common Data Platform (CDP) as the primary application to access client data. Utilizing a SQL server connection, the application directly queries client-specific databases. Clients provide their data to Cloudmed via a secured FTP site. The internal Extract Load team utilizes the provided data to create the client databases. Separate databases are established for each client.

Access to data within CDP is administered utilizing the Varonis DataPrivilege access control application. Cloudmed users are only granted access to specific client databases when they are assigned to a project. Entitlement reviews are completed semi-annually within DataPrivilege to ensure unnecessary access is disabled or terminated. The Internal Applications group enhances and maintains CDP as needs arise from the business. CDP is installed on Cloudmed laptops and may only be accessed while connected to the Cloudmed network. CDP is not web-facing and cannot be accessed through a non-Cloudmed computer.

People

Cloudmed has a staff of approximately 600 employees organized across the following functional areas:

Board of Directors

The Board of Directors oversees the organization and accepts its oversight responsibilities for the company. Board meetings are held at least quarterly to review internal control performance, risk management and company financials.

Executive Management

The Chief Executive Officer (CEO) of Cloudmed is responsible for the overall operation of Cloudmed. Along with the Principals, they comprise the executive leadership team of Cloudmed. Each member of the management team has a distinct and separate responsibility within the Company. The CFO of Cloudmed is responsible for the overall financial accountability of the Company. Cloudmed has assigned the Privacy Officer and PHI Compliance Committee to oversee the policies and procedures related to privacy and personal health information (PHI) within the organization.

Information Security Management Committee

The primary responsibility for the delivery and security of services provided by Cloudmed is assigned to the Information Security Management Committee ("ISMC"). The ISMC includes an IT Security Director in Sacramento, IT Operations Director in San Francisco and IT Operations Managers in San Francisco and Atlanta, who are directly responsible for overseeing the daily information technology operations and security for Cloudmed. In addition, one Principal from each office oversees the committee.

The ISMC meets twice monthly to develop strategic plans and monitor the operations of the organization. Additionally, the ISMC meets with Cloudmed executives regularly to develop short and long-term agendas for developing the technical infrastructure and defining the overall business budgets on an annual basis to ensure the stable operation of the Company. Discussions are held regarding:

- Regulatory, economic, and physical operations
- Industry, competitors, regulatory environments, and consumers
- Potential impact of new business, altered business, acquired or divested business
- Management and philosophies on the system of internal control
- Systems and changes in the technology environment
- Vendor and business partner relationships

Project Management

Business and operational leaders (including Principals, Directors and Managers) meet on an at least quarterly basis to review the business and project plans and actual-to-projected financial results.

Policies and Procedures

Cloudmed's policies and procedures provide guidance for establishing an effective business environment for Cloudmed operations. Supported by the Information Security Policy, the goal of Cloudmed's policies and procedures is to drive critical business processes and activities in a manner that addresses and reduces key risks.

Cloudmed's policies and procedures address significant aspects of information technology governance, security, and operations, including, without limitation, the following topics:

- Information security requirements

- Asset classification and control
- Physical and environmental security
- Communications and operations
- Access control
- System development and maintenance
- Business continuity management
- Regulatory compliance

Data

Cloudmed treats data received from customers with the utmost sensitivity and restricts administrative access to resources based on role. Data is provided to Cloudmed by clients through a secure FTP site and is then internally loaded to client-specific CDP databases. Access to data in both locations is limited to necessary personnel. Formal data retention and disposal procedures are defined within the Information Security Policy to guide the secure disposal of the company's and customers' data.

Third-Party Relationships

Cloudmed's vendors are managed via a Vendor Management Program.

Risks posed by vendors are assessed annually and when a new vendor is contracted. Documentation provided by third party vendors is reviewed to help ensure that the providers are in compliance with security and confidentiality policies.

Relevant Aspects of the Control Environment, Risk Assessment Process, Monitoring Controls and Information and Communication

Control Environment

Management Control

Cloudmed's control environment reflects the position taken by the executive management team concerning the importance of controls and the emphasis given to controls in its policies and procedures. Cloudmed's control environment reflects the overall attitude, awareness, and actions of management and employees concerning the importance of controls and its emphasis within Cloudmed.

Integrity and ethical values are essential components of the control environment, affecting the design, administration, and monitoring. Cloudmed communicates organizational integrity and values through the actions of executive leadership, documented policies and the employee handbook.

Management has procedures in place to limit the ability of employees to commit fraud. Management reviews the entity's compensation and performance evaluation programs annually to identify potential incentives and pressures for employees to commit fraud.

The lines of authority and employee responsibility are established throughout the business units of the organization and are communicated through (1) management philosophy and operating style, (2) organizational structure, (3) job descriptions, and (4) policies, standards, and procedures. The importance of security and availability is emphasized within Cloudmed through the establishment and communication of policies and procedures and is supported by investment in resources and people to carry out the policies. The security commitments are communicated to both internal and external users as appropriate. In designing its controls, Cloudmed has taken into consideration the relevance of controls to meet the relevant trust criteria.

Controls Related to Personnel

Personnel policies and procedures are documented in the Employee Handbook and Information Security Policy Pamphlet and available to employees via the intranet. Upon hire, all employees must sign acknowledgement forms stating they have read and understood both the Employee Handbook and Information Security Policy, which include non-disclosure agreements and a confidentiality agreement. Rules outlining acceptable and inappropriate use of systems and computer equipment are defined in the Acceptable Use Policy found within the Employee Handbook. Organizational charts are in place to communicate key areas of authority, responsibility and appropriate lines of reporting to personnel. Current job descriptions exist that describe primary job functions and responsibilities. Employee job descriptions which include a position summary and describe major duties and responsibilities are developed by the department managers. In addition, the following controls regarding personnel are implemented:

- New employee hiring procedures are in place to guide the hiring process and include verification that candidates possess the required qualifications to perform the duties as outlined in the job description.
- Cloudmed performs employment screening and new employee orientation. Criminal background checks are performed prior to employment for all prospective employees who will have access to customer data.
- Security policies for the use of computers and technology are included in the Employee Handbook, Corporate Code of Conduct and Information Security Policy Pamphlet. Employees are required to sign an acknowledgment that they have read and agree to abide by the policies outlined in the Code of Conduct. Training on security policies and the protection of confidential information is provided annually.
- Policies and procedures include disciplinary actions, which may result in termination for employees who are found to be in violation of the Company's standards.
- Management performs annual performance evaluations to communicate and hold individuals accountable for performance of internal control responsibilities.
- Employees are cross trained to provide sufficient backup in the event of unexpected illness, termination, resignation or promotion. Job descriptions are developed and maintained by management with the assistance of the Human Resources department.
- New hires and users requesting access to the network domain are required to acknowledge in writing that they have read and understood the documented policies and procedures that outline the system requirements in the Information Security Policy.
- Employees are removed from their positions when terminated or discharged. Passwords, keys and electronic access badges are obtained/disabled from terminated employees. Physical and logical access is removed through a standard user access de-provisioning procedure.
- Security awareness and HIPAA compliance training are administered to employees on an annual basis to communicate security policies to employees and make sure employees understand Cloudmed security standards. Management monitors compliance with training requirements on a yearly basis.

Management maintains separation of duties within the organization through defined roles and responsibilities, as well as physical and logical security controls.

Information and Communication

Cloudmed management uses various and tailored methods to communicate with employees. A few of the key reasons to communicate include sharing company and industry news, contacting all

employees in the event of a significant event, and ensuring employees understand company policies, standards, and procedures. Examples of communication methods include new hire orientation and training, online virtual meetings, email, internal Knowledge Base, all-employee meetings, project team meetings, etc.

A system description is documented that includes the services provided, data, people, software, infrastructure, procedures, control environment, risk assessment, monitoring, and information and communication systems. The system description is communicated to authorized internal and external users. Dataflow diagrams are prepared and reviewed identifying critical systems and sensitive information that explain storage, processing, and transmission of covered information.

Customer contracts, service-level agreements, and vendor contracts are negotiated before performance or receipt of service. The agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners. Client agreements and statements of work which describe Cloudmed's systems and its boundaries and responsibilities are provided to customers during the onboarding process. Signed nondisclosure agreements are required before sharing information designated as confidential with third parties.

The entity's service commitments and requirements are documented in customer contracts along with security and confidentiality commitments. The contracts are updated, and a signature is obtained should the confidentiality practice change.

Risk Assessment Process

Risk is managed as part of ongoing operations. Cloudmed uses risk assessments to identify, quantify and prioritize risks against criteria for risk acceptance and objectives within the organization. The results of the risk assessments are used as a guide to determine the appropriate management action and priorities for managing information security and operational risks in order to implement controls selected to protect against these risks. A formal risk assessment is performed on an annual basis. Cloudmed’s ISMC is responsible for performing the risk assessment process. A documented risk management policy is used to guide individuals when performing the risk assessment process. The following areas are part of the risk assessment process:

- Security Risks: Ongoing security threats to the organization are identified and assessed as to the potential impact to Cloudmed. The ISMC meets at least monthly to review emerging risks external to Cloudmed (including new threats identified by the security community), issues that are currently affecting Cloudmed, areas where there are gaps in the systems and new processes to adequately protect Cloudmed.
- Operational Risks: Changes to the system have the potential to affect the performance of a service being provided. Examples of operational risk are patching systems, changes to system hardware and firewall modifications. Change Management is utilized to manage the risk of day-to-day operational changes to the system.
- Security Policy Exception Handling: If there is a technology or business constraint to adhering to Cloudmed IT Security Policies, the ISMC evaluates whether to grant the exception. This is evaluated based on Cloudmed’s risk assessment process. A critical aspect to the exception decisions is whether there are compensating controls to address the risk. Compensating controls must satisfy the following criteria:
    - Meet the intent and rigor of the original requirement
    - Provide a similar level of defense as the original requirement, such that the compensating controls sufficiently offset the risk that the original requirement was designed to defend against.

The risk management program includes the use of insurance to minimize the financial impact of any loss events.

An inventory listing of all hardware and software within the scope of services are maintained and reviewed on at least an annual basis during the risk assessment process.

Monitoring

Cloudmed Senior Management meets regularly to develop strategic plans, monitor the operation of the organization and review priorities related to Cloudmed services. The ISMC monitors the effectiveness of internal security controls on a regular basis. Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches.

The ISMC is responsible and accountable for developing and maintaining the Information Security Program, and changes and updates to the security policies. The PHI Compliance Committee, under the management of the Privacy Officer, is responsible for documenting, implementing and updating privacy policies. Together, the ISMC and the PHI Compliance Committee ensure that audits are performed, policies are updated, Incident Response and Disaster Recovery Plans are exercised, and HIPAA and information security awareness training is delivered to all employees.

Cloudmed uses a Host-based Intrusion Detection System (HIDS) that monitors each server in real-time, to alert of possible malicious activity on its systems. HIDS monitors behavior at/on the hosts themselves and is set up to watch the behavior of the services used and to flag out of the ordinary conditions. Detected IDS vulnerabilities are triaged by the Network Operations/IT Security team and monitored through resolution. It also provides a source of information for remediation or analysis.

Cloudmed monitors systems for the following anomalous behavior:

- Excessive or unusual log-in and system activity, specifically from inactive user accounts
- Excessive or unusual remote access activity

Cloudmed stores security-related log files for all client-related server deployments. These centralized logs contain authorization and authentication entries and are maintained for a minimum of one year.

Cloudmed has contracted with third-party vendors to perform penetration testing and vulnerability assessments. The Security Operations team utilize a vulnerability management program to continuously monitor the application environment. They also review an external vulnerability scan report of the production network on a monthly basis. Identified security vulnerabilities are reported to senior management if necessary and corrective action plans are established. Third-party security specialist performs annual penetration tests of the production environment which is reviewed by the Security Operations team.

Cloudmed's IT security group monitors the security impact of emerging technologies and the impact of applicable laws or regulations are considered by Management. The HR, PHI Compliance and ISMC track compliance and legislative requirements, including but not limited to security and privacy based on geographic jurisdiction.

A file integrity tool is utilized to monitor for changes to the production environment and send notifications to authorized personnel. The ability to modify the file integrity tool is restricted to user accounts accessible by authorized personnel.

The security monitoring applications are configured to alert IT personnel via e-mail notifications when certain defined thresholds have been reached.

Management and Review Activities

Cloudmed's management and supervisory staff monitor the quality of internal control performance as a routine part of their activities. To assist them in this monitoring, Cloudmed has implemented a

series of management reports that measure the results of various activities involved in supporting Security Environment System plans and objectives. Management reviews key indicator reports and action is taken as necessary.

Cloudmed assesses its internal controls against the NIST Cybersecurity framework and new controls are adopted using a risk-benefit approach including compliance and regulatory risk.

Executive management meets monthly to provide project status, discuss workload, schedules and other issues as necessary. In addition, the IT Managers meet regularly to discuss operational initiatives and assess operational performance at the department level.

Security Administration

The IT department under the authority of the IT Operations Director is responsible for oversight of network security and ensuring secure and hardened configurations of the firewall, antivirus, Windows and Linux servers, and user administration. Network security events, including administrator activity, are logged and reviewed on an as-needed basis. The in-scope systems, such as CDP and the associated servers, are configured to log events and send e-mail notifications to IT Operations personnel when certain events have occurred.

Documented standard build procedures are utilized for installation and maintenance of production servers and include the use of an access control system to restrict access to authorized users. Access to production executables and data is authorized or denied based on the user's level of access. Access is based on credentials (user ID and password as well as two-factor authentication) that authenticate the user. Users have a unique username and are assigned to a user group based on their job responsibilities.

The IT department performs the creation and removal of user accounts. New system users are registered and authorized prior to being issued system credentials and granted the ability to access the system. The Human Resources department notifies the IT department about the employment of a new hire and the IT department provisions the user account as requested. A documented access request form and manager approval is used to request the access.

Procedures have been developed to help ensure employee terminations are communicated to relevant department personnel. Employee profiles are disabled upon notice of termination. Reactivation or use of a terminated employee's ID can only be performed using the ticketing system and must include the purpose and justification of the access, the systems that are to be reactivated, and the time period for which the account will be active. The account is reset with a new password and is activated for the time period requested. Use of the account is logged and reviewed by security personnel. User accounts are reviewed on a semi-annual basis to help ensure that access levels are appropriate based on job descriptions.

Application Security Controls

The following application security controls have been implemented:

- Detects and blocks code injection attacks.
- In-application administrative functions such as report writing require an additional security token to perform those functions.
- IP addresses that have a poor RBL (Realtime Blackhole List) reputation are reviewed and require two-factor verification before allowing a user to log in.
- Two-factor authentication using SafeNet Authentication client is added to all endpoints.
- Employee remote access is controlled via VPN.
- New applications are reviewed against an enhanced web application security testing platform.

- Employee access to client data is reviewed and validated semi-annually.

Logical Security

The following logical access controls have been implemented:

- Management has established policies and procedures pertaining to user account management.
- User access reviews are performed on a semi-annual basis to ensure that access to data was restricted.
- User access is restricted on a "need to know" basis using the principle of least privilege.
- Predefined security groups are utilized to assign role-based access privileges and segregate access to data.
- Unique user IDs are assigned to individual users.
- Authentication to the network and applications requires a unique user ID, strong password and a 2nd factor.
- Authentication to client data requires a business need, management approval, and two-factor authentication consisting of login credentials and a hardware authentication device that supports one-time passwords.
- Cloudmed has a Password Policy and Password Construction Standard.
- User access is revoked in a timely manner when there is no longer an affiliation between the user and Cloudmed.
- Administrator and local user access rights to Cloudmed's network and servers are limited to authorized personnel based on job function.
- Shared accounts are prohibited unless documented approval is obtained by a member of the Executive Management team member.

Physical Security

The following physical access controls have been implemented:

- The data center is a secured facility and access is controlled by the use of proximity badge readers. Access is restricted only to individuals with a business need for entry.
- Cameras are used for continuous monitoring of critical entry points within the facility. During non-prime shift operations, motion detectors and an alarm system are used for facility monitoring.
- Entry to all offices is controlled by the use of a proximity badge reader. During non-prime shift operations, access is further restricted by building security guards within the tenant common spaces of the buildings.
- All access to the data center and facility is logged and monitored.
- Visitors must sign the visitor log.
- Visitors require an escort at all times
- Physical access is revoked for employees as a component of the employee termination process.
- Physical access to the data center is controlled via a badge reader and access is restricted to authorized IT personnel.

Remote Access

Cloudmed has defined standards, procedures and restrictions for connecting to Cloudmed internal networks(s) from external hosts via remote access technology. Cloudmed resources are protected by these controls from unauthorized use and malicious attack that could result in loss of information, damage to critical applications, loss of revenue and damage to Cloudmed's public image.

These standards, procedures and restirctions apply to all Cloudmed employees who utilize Cloudmed or personally owned devices to access the organization's data and networks remotely. Employees utilizing remote access privileges are required to acknowledge Cloudmed remote access requirements. Encrypted VPNs are required for remote access to production and enforce two-factor authentication.

Environmental Controls

Cloudmed takes a proactive approach to providing reliable comprehensive payment review services. We utilize a secure network operations center, redundant failover technology, redundant power sources and we replicate all data between two primary data centers to seamlessly continue business in the event of an outage.

Cloudmed's environment is designed to be flexible which allows us to satisfy the varying services and needs of customers.

The server environment is monitored at any time, all year around (24x7x365) and includes:

- Automatic "out of range" alerts for immediate attention.
- Three-phase power is supplied to the data center and the air handling units.
- Data center temperature and humidity levels are controlled by redundant air conditioning units.
- Emergency power to the data center is supplied by an uninterruptible power supply (UPS) system.
- The UPS also provides power to the air handling units in the event of a power disruption.
- The data center is equipped with fire detection and protection devices.

Virus Protection

A central antivirus server is configured to protect registered production Windows servers and workstations with antivirus software using the following configurations:

- Scan for updates to antivirus definitions and update registered clients on a daily basis.
- Scan registered clients on a weekly basis.

Cloudmed uses Sophos Endpoint Protection, which utilizes cloud technology to deliver updates to Cloudmed assets regardless of whether they are connected to Cloudmed's networks. The security suite is centrally managed and helps to limit the possibility of disruptions that could compromise the security of client data and Cloudmed assets.

Server Security

Cloudmed provisions and deploys infrastructure components with an approach that allows Cloudmed to automate workflows, provision hardware consistently, ensure appropriate services are running, and manage changes and configurations. Web servers utilize secure sockets layer (SSL) encryption for web communication sessions.

Specific Server hardening methods include:

- SSH is used to access the servers remotely.

- HTTPS is used to access any web services.
- Aside from the configuration changes to harden SSH and SSL, only required services are running on the systems (i.e., only essential services are listening for network connections).

Firewall Management

Cloudmed maintains and manages the use of multi-tiered firewalls in the demilitarized zone (DMZ). To protect Cloudmed servers from direct access to the Internet, the web servers are located behind perimeter firewalls, and the database servers are located behind a second pair of firewalls. The connection to the client's network is through VPN encrypted tunnels and is terminated on a firewall in the Cloudmed network.

Data Encryption

Cloudmed uses a combination of full disk encryption and database encryption to secure data at rest. Key encryption management software is used to create and control the keys used to encrypt client data. Data backups are encrypted, stored securely, and rotated according to schedule.

Policies are in place that prohibits the transmission of sensitive information over the Internet or other public communications paths unless it is encrypted. Cloudmed supports 256-bit asymmetric cryptography encryption (SSL) for data in motion. Data is signed using a secure certificate certified by a trusted certificate authority. Data from users must be part of a valid session authenticated by a username/password combination.

ISP Redundancy

Redundant internet bandwidth is available in both primary data centers and branch offices, utilizing different carriers and different paths to help eliminate a single point of failure for staff.

Data Backup and Recovery

Backups are made using an automated system which monitors backups for failures. Backups of systems, applications and network files are performed daily. Access to the backup utility is restricted to authorized employees.

Cloudmed employs several methods to protect data stored within the system. In the case of data corruption or hardware failure, we maintain online, near-line, and offline copies of data residing on the system.

There are three failover methods used for data recovery:

1. In the event of a hard drive failure of the database cluster, there is an online, failover replica of the primary database and a local replica.
2. The second solution is a near real-time replication of the live data to the other primary facility.
3. The third is the long-term, offline backup solution that creates an archive of the data to be restored, either in part or in whole, in the case of system failure.

Business Resiliency

Incident Response Plan

Cloudmed has incident response policies and procedures in place that include an escalation plan based on the nature and severity of the incident to senior management as necessary. The incident response policy addresses remedial actions for lack of compliance with the policy. Documented escalation procedures for reporting security incidents are provided to internal users to guide them in identifying and reporting failures, incidents, concerns and other complaints. Cloudmed has also implemented an incident Response Guide to define procedures to recover from identified security incidents.

Management teams meet periodically to discuss any identified incidents and design corrective measures to ensure that incidents are resolved. An automated ticketing system is used to document identified security violations, responses, and resolution.

Although computer security incidents may take many forms and involve many devious means, there are certain types of attacks that occur more frequently than others. Cloudmed has defined the following types of incidents:

- Internal threat – An internal threat is any instance of a user misusing resources, running malicious code or attempting to gain unauthorized access to an application. Examples include unauthorized use of another user's account, unauthorized use of system privileges and execution of malicious code that destroys data. More significant internal threats may include an otherwise authorized system administrator who performs unauthorized actions on a system.
- External threat – An external threat is any instance of an unauthorized person attempting to gain access to systems or cause a disruption of service. Examples include disruption/denial of service attacks, mail spamming and execution of malicious code that destroys data or corrupts a system.
- Malicious code – Is typically written to mask its presence thus it is often difficult to detect. Self-replicating malicious code, such as viruses and worms, can replicate so rapidly that containment can become an especially difficult problem. Dealing with malicious code attacks requires special considerations.

The IT Department takes appropriate and necessary actions based on the nature and scope of incidents.

Patch Management

Cloudmed hardware (including network appliances, servers, and workstations) is patched with the latest appropriate software updates in order to reduce system vulnerability, maintain performance and protect the entire network from malicious attack. Cloudmed obtains advisories and notification of available patches from third parties on a regular basis and leverages Tenable to monitor vulnerabilities on servers and endpoints.

Change Management

Change management policies and procedures are documented that outline change management separation of duties such that authorization, development, testing, and implementation are segmented functions within the process. Changes made to in-scope systems are authorized, tested, and approved prior to implementation. Incidents requiring a change follow the change management policy also. Change requests include Back-out/Recovery Plan describing how a change will be dealt with in the production environment should an issue occur during roll-out or post-implementation.

Changes to a production environment that are deemed "emergencies" may be fast-tracked through a Change Control process upon approval from the Director of IT Operations. In such cases, a documented change request via the ticketing system must be completed and logged after the emergency is resolved.

The ability to promote source code, infrastructure changes, and patches to the production environments is restricted to user accounts accessible by authorized personnel. Where such segregation is not practical, management has implemented additional controls. For each application, there are separate production, test/acceptance, and development environments and repositories are used to control source code for in-house developed systems.

Confidential information is protected during the system design, development, testing, implementation, and change processes to meet the entity's confidentiality commitments and system requirements. Client data is not utilized for application change control testing.

The Cloudmed data center change management and control process includes:

- Scheduled and unscheduled changes
- Hardware and software changes and upgrades

As a subset of Change Management, Cloudmed's Configuration Management process identifies, tracks, and audits all critical data center configuration items.

Security Awareness Training

Cloudmed maintains a security awareness program through various mechanisms including:

- Employee orientation program,
- Annual security awareness training,
- Periodic email communications from information security and management, and
- Role-specific security training (such as secure coding).

System Incidents During the Period

There were no incidents during this reporting period that would affect report users' understanding of how Cloudmed's Security Environment System was used to provide the service during the period from April 1, 2020, through March 31, 2021.

Disclosure of Significant System Changes

Throughout the period from April 1, 2020, through March 31, 2021 Cloudmed made the following significant system changes:

- In December 2020, migrated from on-premises Exchange servers to Office 365 including implementation of Okta SSO for dual factor authentication. This change was in preparation for anticipated tenant migration as part of Triage's merger with Cloudmed.
- In January 2021, dual factor authentication for laptops was shifted from SafeNet certificate-based e-tokens to Duo.
- Remote access to Cloudmed systems migrated from Cisco AnyClient to Fortinet VPN in Q1 2021 to facilitate use of Okta SSO for dual factor authentication into our environment. This was necessitated by the phasing out of physical e-tokens as described above.

Subservice Organizations

There were no subservice organizations that are likely to affect report users' understanding of how Cloudmed's Security Environment System was used to provide the service during the period from April 1, 2020, through March 31, 2021.

Complementary User Entity Controls

This section highlights the internal control responsibilities that Cloudmed believes should be present at user entities and considered in developing its control objectives described in this report. For user entities to rely on controls reported herein, each user entity must evaluate its own internal controls to determine if the following procedures are in place. The following list of activities is intended to address those controls surrounding the interaction between each user entity and Cloudmed. These

control activities, when coupled with the control activities at Cloudmed, were designed to achieve the control objectives specified by Cloudmed's management team. Accordingly, this list does not purport to be, and is not, a complete list of the control activities that provide a basis for the assertions underlying the financial statements of user entities.

CONTROL ACTIVITIES EXPECTED TO BE IMPLEMENTED AT USER ENTITIES	APPLICABLE TRUST SERVICES CRITERIA
The accuracy and completeness of customer information provided on a timely basis to Cloudmed.	CC6.7
Ensuring that only authorized and properly trained users are allowed to access and use Cloudmed's Services, including but not limited to information access control once transferred by Cloudmed to the SFTP server, implementing logical access controls to the information provided by Cloudmed, etc.	CC6.2, CC6.3
Maintaining compliance with laws and regulations regarding statement notices and disclosures.	CC7.5
Ensuring that Cloudmed is provided with an accurate and updated list of customer contacts and customer contact information.	C1.1

Section 4: Trust Services Criteria, Related Controls, Test of Controls and Results

Tests of Operating Effectiveness

The tests applied to test the operating effectiveness of controls are listed alongside each of the respective control activities within the Testing Matrices. Such tests were considered necessary to evaluate whether the controls were sufficient to provide reasonable, but not absolute, assurance that the applicable trust services criteria were achieved during the review period. In selecting the tests of controls, various factors were considered including, but not limited to, the following:

- The nature of the control and the frequency with which it operates;
- The control risk mitigated by the control;
- The effectiveness of entity-level controls, especially controls that monitor other controls;
- The degree to which the control relies on the effectiveness of other controls; and
- Whether the control is manually performed or automated.

The types of tests performed with respect to the operational effectiveness of the control activities detailed in this section are briefly described below:

Test	***Description***
Inquiry	Inquiry of appropriate personnel and corroboration with management
Observation	Observation of the application, performance, or existence of the control
Inspection	Inspection of documents and reports indicating performance of the control
Reperformance	Reperformance of the control

Trust Services Criteria, Related Controls, and Test of Controls

Applicable Trust Services Criteria, Related Controls, and Service Auditor's Tests of Controls and Results

Security
Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

Security refers to the protection of:

- Information during its collection or creation, use, processing, transmission, and storage and
- Systems that use electronic information to process, transmit or transfer, and store information to enable the entity to meet its objectives. Controls over security prevent or detect the breakdown and circumvention of segregation of duties, system failure, incorrect processing, theft or another unauthorized removal of information or system resources, misuse of software, and improper access to or use of, alteration, destruction, or disclosure of information.

Confidentiality
Information designated as confidential is protected to meet the entity's objectives.

Confidentiality addresses the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives. Information is confidential if the custodian (for example, an entity that holds or stores information) of the information is required to limit its access, use, and retention and restrict its disclosure to defined parties (including those who may otherwise have authorized access

within its system boundaries). Confidentiality requirements may be contained in laws or regulations or in contracts or agreements that contain commitments made to customers or others. The need for information to be confidential may arise for many different reasons. For example, the information may be proprietary, intended only for entity personnel.

Confidentiality is distinguished from privacy in that privacy applies only to personal information, whereas confidentiality applies to various types of sensitive information. In addition, the privacy objective addresses requirements regarding the collection, use, retention, disclosure, and disposal of personal information. Confidential information may include personal information as well as other information, such as trade secrets and intellectual property.

Trust Services Criteria Not Applicable to The Examination

Availability
Information and systems are available for operation and used to meet the entity's objectives.

Availability refers to the accessibility of information used by the entity's systems, as well as the products or services provided to its customers. The availability objective does not, in itself, set a minimum acceptable performance level; it does not address system functionality (the specific functions a system performs) or usability (the ability of users to apply system functions to the performance of specific tasks or problems). However, it does address whether systems include controls to support accessibility for operation, monitoring, and maintenance.

Processing integrity
System processing is complete, valid, accurate, timely, and authorized to meet the entity's objectives.

Processing integrity refers to the completeness, validity, accuracy, timeliness, and authorization of system processing. Processing integrity addresses whether systems achieve the aim or purpose for which they exist and whether they perform their intended functions in an unimpaired manner, free from error, delay, omission, and unauthorized or inadvertent manipulation. Because of the number of systems used by an entity, processing integrity is usually only addressed at the system or functional level of an entity.

Privacy
Personal information is collected, used, retained, disclosed, and disposed to meet the entity's objectives.

Although confidentiality applies to various types of sensitive information, privacy applies only to personal information.

The privacy criteria are organized as follows:

- Notice and communication of objectives. The entity provides notice to data subjects about its objectives related to privacy.
- Choice and consent. The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to data subjects.
- Collection. The entity collects personal information to meet its objectives related to privacy.
- Use, retention, and disposal. The entity limits the use, retention, and disposal of personal information to meet its objectives related to privacy.
- Access. The entity provides data subjects with access to their personal information for review and correction (including updates) to meet its objectives related to privacy.
- Disclosure and notification. The entity discloses personal information, with the consent of the data subjects, to meet its objectives related to privacy. Notification of breaches and incidents

is provided to affected data subjects, regulators, and others to meet its objectives related to privacy.

- Quality. The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet its objectives related to privacy.
- Monitoring and Enforcement. The entity monitors compliance to meet its objectives related to privacy, including procedures to address privacy-related inquiries, complaints, and disputes.

Cloudmed's Controls Mapped to the Security and Confidentiality Criteria

CRITERIA NUMBER	CONTROL NUMBER	TRUST SERVICES CRITERIA
CONTROL ENVIRONMENT		
CC1.1	TCN001 TCN002 TCN003 TCN004 TCN005 TCN006	The entity demonstrates a commitment to integrity and ethical values.
CC1.2	TCN001 TCN005 TCN007 TCN008 TCN009 TCN010 TCN011	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.
CC1.3	TCN001 TCN012	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.
CC1.4	TCN002 TCN012 TCN013 TCN014 TCN015	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.
CC1.5	TCN004 TCN009 TCN010 TCN016	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.
COMMUNICATION AND INFORMATION		
CC2.1	TCN017 TCN018 TCN019 TCN020 TCN021 TCN022 TCN023 TCN024	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.
CC2.2	TCN014 TCN025 TCN026 TCN027 TCN028	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.
CC2.3	TCN025 TCN029 TCN030 TCN031	The entity communicates with external parties regarding matters affecting the functioning of internal control.

CRITERIA NUMBER	CONTROL NUMBER	TRUST SERVICES CRITERIA
	TCN032	
RISK ASSESSMENT		
CC3.1	TCN028 TCN033 TCN034	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.
CC3.2	TCN001 TCN007 TCN018 TCN019 TCN020 TCN022 TCN033 TCN035 TCN036 TCN037	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.
CC3.3	TCN005 TCN038 TCN039	The entity considers the potential for fraud in assessing risks to the achievement of objectives.
CC3.4	TCN022 TCN033 TCN040	The entity identifies and assesses changes that could significantly impact the system of internal control.
MONITORING ACTIVITIES		
CC4.1	TCN041 TCN042	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.
CC4.2	TCN027 TCN043	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.
CONTROL ACTIVITIES		
CC5.1	TCN033 TCN044 TCN045	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.
CC5.2	TCN044 TCN045	The entity also selects and develops general control activities over technology to support the achievement of objectives.
CC5.3	TCN002 TCN005 TCN045	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.
LOGICAL AND PHYSICAL ACCESS CONTROLS		
CC6.1	TCN046 TCN047 TCN048 TCN049 TCN050 TCN051 TCN052 TCN053 TCN054	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

CRITERIA NUMBER	CONTROL NUMBER	TRUST SERVICES CRITERIA
CC6.2	TCN053 TCN055 TCN056	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.
CC6.3	TCN047 TCN057	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.
CC6.4	TCN058 TCN059 TCN060 TCN061	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.
CC6.5	TCN062	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.
CC6.6	TCN018 TCN019 TCN020 TCN021 TCN050 TCN063 TCN064	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.
CC6.7	TCN050 TCN065 TCN066 TCN067	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.
CC6.8	TCN068 TCN069 TCN070 TCN071	The entity implements controls to prevent and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.
SYSTEM OPERATIONS		
CC7.1	TCN020 TCN036 TCN048 TCN072	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.
CC7.2	TCN018 TCN019 TCN020 TCN021 TCN048 TCN064 TCN067 TCN068 TCN070	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.

CRITERIA NUMBER	CONTROL NUMBER	TRUST SERVICES CRITERIA
CC7.3	TCN027 TCN073 TCN074 TCN075	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.
CC7.4	TCN027 TCN076 TCN077	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.
CC7.5	TCN076 TCN078	The entity identifies, develops, and implements activities to recover from identified security incidents.
CHANGE MANAGEMENT		
CC8.1	TCN070 TCN079 TCN080 TCN081 TCN082 TCN083 TCN084 TCN085 TCN086	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.
RISK MITIGATION		
CC9.1	TCN033 TCN087 TCN088	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.
CC9.2	TCN054 TCN088 TCN089 TCN090 TCN091	The entity assesses and manages risks associated with vendors and business partners.
ADDITIONAL CRITERIA FOR CONFIDENTIALITY		
C1.1	TCN092 TCN093	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.
C1.2	TCN001 TCN094	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

Criteria Mapped to Cloudmed Controls and Auditor Testing Performed and Results

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN001	CC1.1 CC1.2 CC1.3 CC3.2	Cloudmed has an Organizational chart and job responsibilities that identifies reporting lines and indicates management levels within the hierarchy. Cloudmed has detailed job descriptions for all levels within their reporting lines.	Inspected the organizational chart from the company to determine whether it describes functional areas and reporting structures within functional areas and that reporting hierarchies were defined.	No exceptions noted
TCN002	CC1.1	Personnel must pass a background check before they may be hired.	Inspected a random sample of new hire employee files to confirm that a background check must be completed prior to being hired.	No exceptions noted
TCN003	CC1.1	The Company has documented an Employee Handbook, which is reviewed, updated if applicable, and approved by Senior Management.	Inspected the Employee Handbook to determine it included guidance regarding employee ethics and code of business conduct and was reviewed during the evaluation period.	No exceptions noted
TCN004	CC1.1 CC1.5	Policies and procedures include disciplinary actions, which may result in termination for employees who are found to be in violation of the Company's standards.	Inspected Information Security Policy, Cybersecurity Incident Response Policy, and Employee Handbook to determine that a disciplinary process was in place.	No exceptions noted
TCN005	CC1.1 CC1.2 CC3.3 CC5.3	Employees must sign an acknowledgment form upon hire indicating that they have been given access to and read the Employee Handbook and understand their responsibility for adhering to the Code of Conduct.	For a sample of employee records, confirmed that employees signed an acknowledgment form upon hire indicating that they have been given access to and read the Employee Handbook and understand their responsibility for adhering to the Code of Conduct.	One of twelve employees selected for testing did not have a completed acknowledgment form indicating that they had been given access to the employee handbook and understand the code of conduct.

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN006	CC1.1	Cloudmed has identified, documented and implemented an Acceptable Use Policy.	Inspected Cloudmed's Acceptable Use policy to determine that the entity has set rules for system users that describe their responsibilities and expected behavior with regards to information and information system usage.	No exceptions noted
TCN007	CC1.2 CC3.2	Board of directors meetings are held on at least a quarterly basis to review internal control performance.	Inquired of management to confirm Board of Director meetings are held on at least a quarterly basis to review internal control performance.	No exceptions noted
TCN008	CC1.2	Policies and procedures have been prepared and are available to employees via the Intranet.	Inquired of management to confirm that Cloudmed utilizes their Intranet for storage of the entity Policies and Procedures and that all employees have access.	No exceptions noted
TCN009	CC1.2 CC1.5	The Information Security Management Committee is responsible and accountable for developing and maintaining the Information Security Program, and changes and updates to the policies.	Inquired of Management to determine that the Information Security Management Committee is responsible and accountable for developing and maintaining the Information Security Program, and changes and updates to the policies.	No exceptions noted
TCN010	CC1.2 CC1.5	The PHI Compliance Committee is responsible for implementing, documenting and updating privacy policies.	Inquired of Management to confirm the PHI Compliance Committee is responsible for documenting and updating Cloudmed's Privacy policies.	No exceptions noted
TCN011	CC1.2	The board of directors identifies and accepts its oversight responsibilities in relation to requirements and expectations.	Inquired of Management to determine whether the board of directors identifies and accepts its oversight responsibilities in relation to requirements and expectations.	No exceptions noted
TCN012	CC1.3 CC1.4	Documented position descriptions are in place to define the skills, responsibilities, and knowledge levels required for jobs.	Inspected a sample of position descriptions from the company and obtained job descriptions for the selected roles to confirm all criteria is defined.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN013	CC1.4	New employee hiring procedures are in place to guide the hiring process and include verification that candidates possess the required qualifications to perform the duties as outlined in the job description.	Inquired of management that a procedure is in place to guide the hiring of new employees to verify that they have appropriate qualifications to meet their job descriptions.	No exceptions noted
TCN014	CC1.4 CC2.2	Employees are required to complete privacy and security training on an annual basis to understand their obligations and responsibilities to comply with the corporate and business unit security policies.	Inspected privacy and security training records for a sample of employees to determine whether employees were provided training once hired by the Company	No exceptions noted
TCN015	CC1.1 CC1.4	Management monitors compliance with training requirements on a yearly basis.	Inquired of management to determine that completion of training is monitored by Human Resources.	No exceptions noted
TCN016	CC1.5	Executive Management performs annual performance evaluations to communicate and hold individuals accountable for performance of internal control responsibilities. The evaluation is signed by management.	Inquired of management to confirm that performance evaluations are conducted at least annual to hold individuals accountable for performance and responsibilities. Inspected sample evaluation record to determine that reviews are completed and management signs the evaluation.	No exceptions noted
TCN017	CC2.1	Dataflow diagrams are prepared and reviewed identifying critical systems and sensitive information that explain storage, processing, and transmission of covered information.	Inspected dataflow diagrams to determine that it identifies critical systems and sensitive information relevant to the company compliance with service commitments and system requirements. Data flows were updated annually.	No exceptions noted
TCN018	CC2.1 CC3.2 CC6.6 CC7.2	Any IDS vulnerabilities that are detected are triaged by the Network Operations/IT Security team and monitored through resolution.	Inspected and inquired about the IDS process and reviewed documentation to determine that detected vulnerabilities are triaged by the Network Operations/IT Security team and monitored through resolution.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN019	CC2.1 CC3.2 CC6.6 CC7.2	The Security Operations team reviews an external vulnerability scan report of the production network on a monthly basis at a minimum.	Inquired of management to confirm that the Security Operations team reviews vulnerability scan reports of the production network on a monthly basis. Inspected a monthly meeting report package to confirm that the Security Operations team reviewed external vulnerability scan documentation of the production network on a monthly basis.	No exceptions noted
TCN020	CC2.1 CC3.2 CC6.6 CC7.1 CC7.2	The Security Operations team utilize a vulnerability management program to continuously monitor the application environment.	Observed the NOC and real-time production monitoring tools to determine that a NOC was in place to monitor and manage the production environment including potential vulnerabilities. Inquired of management and inspected a sample of IS management meeting minutes from during the review period to determine that the vulnerability management program to continuously monitor the application environment is routinely discussed.	No exceptions noted
TCN021	CC2.1 CC6.6 CC7.2	Third-party security specialist performs annual penetration tests of the production environment. The Security Operations team reviews penetration test report.	Inspected the annual penetration test report completed by a third-party security specialist to determine that the Security Operations team reviewed the report.	No exceptions noted
TCN022	CC2.1 CC3.2 CC3.4	Cloudmed's IT security group monitors the security impact of emerging technologies and the impact of applicable laws or regulations are considered by Management.	Inspected working file of the IT group's weekly meeting with executive management to verify emerging technologies and the impact of applicable laws or regulations are considered by management.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN023	CC2.1 CC2.3 CC7.2	External users (customers, consumers, suppliers, etc.) are provided with communication channels to report system incidents, concerns, and other complaints via the public website or the application.	Inspected Cloudmed's website and confirmed external users are provided with communication channels to report system incidents, concern, and other complaints. Inquired of management to confirm that users are able to report incidents or concerns to their point of contact or via the main website.	No exceptions noted
TCN024	CC2.1	The data center is equipped with the following environmental protection equipment: • Fire detection and suppression equipment; • uninterruptible power supply (UPS) systems; • backup generators; • air conditioning units; • redundant data communication connections; The data center is monitored for environmental threats and alerts are sent to appropriate management personnel when anomalies are detected.	Observed data center environmental protection equipment has been installed. Inquired regarding environmental threat monitoring and alerts generated during the review period and that appropriate action was taken.	No exceptions noted
TCN025	CC2.2 CC2.3	A system description is documented that includes the services provided, data, people, software, infrastructure, procedures, control environment, risk assessment, monitoring, and information and communication systems. The system description is communicated to authorized internal and external users.	Inspected network descriptions and process flow diagrams to determine whether they were made available to users of the system and the description addresses infrastructure, software, people, procedures, and data for the in-scope technology and locations.	No exceptions noted
TCN026	CC2.2	New hires and users requesting access to the network domain are required to acknowledge in writing that they have read and understood the documented policies and procedures that outline the system requirements in the Information Security Policy.	Inspected signed Acknowledgment Forms to determine whether the Information Security Policy was communicated to internal and external users to understand their responsibilities to comply with security and availability commitments.	Two of twelve employees selected for testing did not have a completed acknowledgment form indicating that they have read and

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
				understood the documented policies and procedures that outline the system requirements in the Information Security Policy.
TCN027	CC2.2 CC4.2 CC7.3 CC7.4	Cloudmed has an Incident Response Plan in place that includes an escalation plan based on the nature and severity of the incident to senior management as necessary.	Inspected the Incident Response Plan to determine that a plan includes different levels of escalation per event category.	No exceptions noted
TCN028	CC2.2 CC3.1	The entity's security commitment is communicated to external users, as appropriate, and those commitments and the associated system requirements are communicated to internal system users to enable them to carry out their responsibilities.	Inspected a sample of business associate agreements outlining the security commitment to external users and the associated internal communication to enable the company to carry out their security responsibilities.	No exceptions noted
TCN029	CC2.3	Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	Inspected a sample of business partners, and service providers agreements to determine that it included defined terms, conditions, and responsibilities of each party.	No exceptions noted
TCN030	CC2.3	The entity's service commitments and requirements are documented in customer contracts. The contracts are updated, and a signature is obtained should the confidentiality practice change.	Inquired of management to obtain an understanding of the management approval process for updates to service commitments and requirements. Inspected documentation for a selection of updates to service commitments and requirements to determine that changes were approved prior to contract issuance.	No exceptions noted
TCN031	CC2.3	Documented escalation procedures for reporting security incidents are provided to internal users to guide users in identifying and reporting	Inspected the Information Security Policy and Breach Notification Policy to determine whether security commitments, as well as, significant processes,	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
		failures, incidents, concerns, and other complaints.	which include responsibility for reporting operational failures, incidents, system problems, concerns, and user complaints (and the process for doing so), are published and available on the entity's intranet.	
TCN032	CC2.3	Client agreements and statements of work which describe Cloudmed's systems and its boundaries and responsibilities are provided to customers during the onboarding process.	Inspected Master Service Agreement to determine that Cloudmed's systems and its boundaries and responsibilities are provided to customers during the onboarding process.	No exceptions noted
TCN033	CC3.1	A formal risk assessment is performed on an annual basis. Risks that are identified are rated using a risk evaluation process and are formally documented, along with mitigation strategies, for management review.	Inspected the risk assessment and confirmed it is performed on an annual basis and that for any significant risks identified, management is responsible for implementing appropriate measure to remediate or manage the risks.	No exceptions noted
TCN034	CC3.1	Human Resources, PHI Compliance and the ISMC track compliance and legislative requirements, including but not limited to security and privacy based on geographic jurisdiction and relays to Cloudmed.	Inquired of the Principal to determine that the entity (Human Resources, PHI Compliance and the ISMC) tracks different laws and regulations, including security and privacy, based on geographic jurisdiction.	No exceptions noted
TCN035	CC3.2	Bi-Weekly Information Security Management Committee meetings are held in-office to discuss job scheduling in addition to use of daily communication, status and operational concerns.	Inquired of the Principal to determine that bi-weekly ISMC meetings are held to discuss job scheduling in addition to use of daily communication, status and operational concerns. Inspected meeting minutes from a sample of ISMC meetings to confirm job scheduling, communication of issues, planning and other concerns are discussed.	No exceptions noted
TCN036	CC3.2	Security reviews and vulnerability assessments are performed by information technology personnel and third-party vendors on a periodic basis. Remediation plans are proposed and monitored through resolution.	Inspected security reviews and vulnerability assessments performed by information technology personnel and third-party vendors to confirm they are completed on a periodic	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
			basis and remediation plans are proposed and monitored through resolution.	
TCN037	CC3.2	Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches.	Inquired of the Principal to confirm management utilizes security monitoring applications and manual reviews to monitor and analyze the in-scope systems for possible or actual security breaches.	No exceptions noted
TCN038	CC3.3	Management has procedures in place to limit the ability of employees to commit fraud.	Inquired of Management to determine procedures in place to limit fraud by employees. Inspected Board minute records to determine that fraud and related topics are discussed during the meetings.	No exceptions noted
TCN039	CC3.3	Management reviews the entity's compensation and performance evaluation programs annually to identify potential incentives and pressures for employees to commit fraud.	Inspected Board minute records to determine that the Human Resources department leads the entity's compensation and performance evaluation program annually. Potential pressures of employees are identified.	No exceptions noted
TCN040	CC3.4	Executive and Operations meet regularly to discuss: • the regulatory, economic, and physical environment in which the entity operates; • the business environment, including industry, competitors, regulatory environment, and consumers; • the potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies; • the management and respective attitudes and philosophies on the system of internal control; • Cloudmed's systems and changes in the technology environment;	Inspected Operation meeting records to determine that biweekly ISMC meeting were held to discuss operation risk and system performance. Inquired of management regarding the topics covered during Board meetings. Inspected Board meeting records to determine that the following items were discussed: • the regulatory, economic, and physical environment in which the entity operates; • the business environment, including industry, competitors, regulatory environment, and consumers; • the potential impact of new	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
		• vendor and business partner relationships.	business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies; • the management and respective attitudes and philosophies on the system of internal control; • Cloudmed's systems and changes in the technology environment; • vendor and business partner relationships.	
TCN041	CC4.1	The security monitoring applications are configured to alert IT personnel via e-mail notifications when certain defined thresholds have been reached.	Inspected the system configuration screen to determine whether monitoring software is used to identify and evaluate ongoing system performance, security threats, changing resource utilization needs, and unusual system activity. Inspected sample email alerts and follow-up action to alerts received.	No exceptions noted
TCN042	CC4.1	Documented escalation procedures are in place to guide employees in reporting, acting upon, and resolving reported events.	Inspected the Incident Response Policy to determine whether security commitments, as well as significant processes, which include responsibility for reporting operational failures, incidents, system problems, concerns, and user complaints (and the process for doing so), are published and available on the entity's intranet.	No exceptions noted
TCN043	CC4.2	Identified security vulnerabilities are reviewed and reported to senior management for review and to establish corrective action plan.	Inspected security testing reports to determine whether identified vulnerabilities were categorized, and a corrective action plan was established and executed.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN044	CC5.1 CC5.2	Cloudmed assesses its internal control against the NIST Cybersecurity Framework and new controls are adopted using a risk-benefit approach including compliance and regulatory risk.	Inquired of management about the NIST Cybersecurity Framework to determine whether the company assesses its internal control against such framework and whether the entity assesses its internal control against Cybersecurity Best Practices and implements new controls when applicable, using a risk-based approach.	No exceptions noted
TCN045	CC5.1 CC5.2 CC5.3	Policies and procedures are in place to protect these applications and the corresponding client data, as well as logical security, physical security, and environmental controls. These procedures cover the following key security lifecycle areas: • data encryption (data at rest, in motion and output); • data management, retention, and secure disposal; • authorization, changes to, and termination of information system access; • management of access and roles; • selection, documentation, and implementation of security controls; • maintenance and support of the security system and necessary back-ups; • incident response; • monitoring security controls and vulnerability management; • maintenance of restricted access to system configurations, superuser functionality, master passwords, power utilities, and security devices; • system hardening; • disaster recovery and business continuity; • change management; • software development; • third-party management.	Inspected the list of Information Security Policies, Procedures, Guidelines and Standards to determine if the criteria were met, a periodic review was performed and were updated if needed.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN046	CC6.1	Documented standard build procedures are utilized for installation and maintenance of production servers and include the use of an access control system to restrict access to authorized users.	Inspected the standard Configuration Policy to determine that procedures are utilized for installation and maintenance of production servers and include the use of an access control system to restrict access to authorized users.	No exceptions noted
TCN047	CC6.1 CC6.3	User access reviews are performed on a semi-annual basis to ensure that access to data was restricted.	Inspected the semi-annual access review documentation to verify that access to data is restricted.	No exceptions noted
TCN048	CC6.1 CC7.1 CC7.2	The in-scope systems are configured to log events and send e-mail notifications to IT Operations upon certain events that have occurred.	Inspected Information Security and Configuration Security Requirements to verify in-scope systems are configured to log access-related events and send e-mail notifications to IT Operations when specified events have occurred.	No exceptions noted
TCN049	CC6.1	The in-scope systems are configured to authenticate users with a unique user account and enforce predefined user account and minimum password requirements.	Inspected evidence to confirm that for each of the in-scope applications, a password or other tool is in place to uniquely identify users and assign appropriate access.	No exceptions noted
TCN050	CC6.1 CC6.6 CC6.7	Encrypted VPNs are required for remote access to production and enforce two-factor authentication.	Inspected the VPN configurations to determine that access to the environment requires MFA in order to allow access.	No exceptions noted
TCN051	CC6.1	Predefined security groups are utilized to assign role-based access privileges and segregate access to data to the in-scope systems.	Inspected the AD listing to determine that predefined groups are allowed access to sections of the environment based on privileges defined.	No exceptions noted
TCN052	CC6.1	Administrator access to the network, applications, databases, and infrastructure is restricted to authorized personnel based on job function.	Inspected the user listing of information systems in-scope and confirmed administrator access to the network, applications, databases, and infrastructure is restricted to	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
			authorized personnel based on job function.	
TCN053	CC6.1 CC6.2	Shared accounts are prohibited unless documented approval is obtained by a member of the Executive Management team member.	Inspected the Information Security policies to determine that shared accounts are strictly prohibited.	No exceptions noted
TCN054	CC6.1 CC9.2	Confidential information is protected during the system design, development, testing, implementation, and change processes to meet the entity's confidentiality commitments and system requirements.	Inspected the Application Development Policy and the CDP Application Development Security Policy to confirm all confidential information is limited to the production environment, which is highly restricted and duly encrypted; therefore, there is no risk of exposing confidential information to system components during design, development, or testing or to the engineers performing such design, development, or testing work.	No exceptions noted
TCN055	CC6.2	Access is revoked for employees as a component of the employee termination process. Reactivation or use of a terminated employee's ID can only be performed using the ticketing system and must include the purpose and justification of the access, the systems that are to be reactivated, and the time period for which the account will be active. The account is reset with a new password and is activated for the time period requested. Use of the account is logged and reviewed by security personnel.	For a sample of employees, inspected tracking system records of terminated employees to determine whether access to the system was removed and verified by the Information Technology team. Inspected Access Control, System Access, and Physical access policies to determine whether documents establish a formal process to grant and deny access to the system components by the Principal.	No exceptions noted
TCN056	CC6.2	New system users are registered and authorized prior to being issued system credentials and granted the ability to access the system.	Inspected the user creation records for a sample of employees to determine whether access was authorized prior to being granted by the IT department.	No exceptions noted
TCN057	CC6.3	Access to in-scope system components requires a documented access request	Inspected access requests forms for a sample of new hires that received access to the in-scope	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
		form and manager approval prior to access being provisioned.	system components to determine that an access provisioning request was approved prior to access being provisioned.	
TCN058	CC6.4	Physical access control systems are in place to restrict access to and within the corporate facility and data center housing the facilities, backup media, and other system components such as firewalls, routers, and servers to properly authorized individuals that include the following: • A Badge access control system in place at the perimeter and within the facilities; • badge access required to access to the data center; • visitor logs recorded visitor access to the corporate facility and the data center; • visitors are required to wear visitor badges while onsite and the badges were distinguishable from employee badges; • visitors required an escort at all times; • visitors are required to surrender their badges upon exit and the badges are disabled upon return.	Observed physical access control systems are in place to restrict access to and within the corporate facility and data center housing the facilities, backup media, and other system components such as firewalls, routers and servers to properly authorized individuals that include the following: • A Badge access control system in place at the perimeter and within the facilities; • badge access required to access to the data center; • visitor logs recorded visitor access to the corporate facility and the data center; • visitors are required to wear visitor badges while onsite and the badges were distinguishable from employee badges; • visitors required an escort at all times; • visitors are required to surrender their badges upon exit and the badges are disabled upon return.	No exceptions noted
TCN059	CC6.4	Physical access is revoked for employees as a component of the employee termination process.	For a walkthrough of one employee, inspected system records of a terminated employee to determine whether physical access to the facilities was removed and verified by the Information Technology team. Inspected Access Control, System Access, and Physical access policies to determine whether documents establish a formal process to grant and	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
			deny physical access to the facilities.	
TCN060	CC6.4	Physical access to the data center is controlled via a badge reader and access is restricted to authorized IT personnel.	Observed physical access to the data center being restricted by a badge reader and that access is restricted to authorized IT personnel.	No exceptions noted
TCN061	CC6.4	Physical access to facilities housing the system (for example, data centers, backup media storage, and other sensitive locations as well as sensitive system components within those locations) is restricted to authorized personnel.	Observed physical access to facilities housing the system is restricted to authorized personnel.	No exceptions noted
TCN062	CC6.5	Formal data retention and disposal procedures are in place to guide the secure disposal of the company's and customers' data.	Inspected data retention and disposal procedures to determine that they were in place.	No exceptions noted
TCN063	CC6.6	A firewall system is in place to filter unauthorized inbound network traffic from the Internet.	Inspected firewall configurations to verify firewall systems are in place to filter unauthorized inbound network traffic from the Internet.	No exceptions noted
TCN064	CC6.6 C7.2	An intrusion prevention/detection system (IDS/IPS) is utilized to analyze and report network events.	Inspected a sample of IDS/IPS report that demonstrate that alerts from the tool are analyzed and report network events.	No exceptions noted
TCN065	CC6.7	Policies are in place that prohibits the transmission of sensitive information over the Internet or other public communications paths unless it is encrypted.	Inspected the Information Security Policy and confirmed it prohibits the transmission of sensitive information over the Internet or other public communication paths unless it is encrypted.	No exceptions noted
TCN066	CC6.7	Web servers utilize secure sockets layer (SSL) encryption for web communication sessions.	Inspected web server evidence to verify that SSL encryption is utilized for web communication sessions.	No exceptions noted
TCN067	CC6.7 CC7.2	Backups are performed daily using an automated system, which monitors the backups for failures. Backup media are encrypted during creation. Backups are rotated on a predefined schedule.	Inquired of management to determine whether backup media is encrypted during creation. Inspected Backup Schedule and	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
			reports to determine that they were performed to meet its objectives.	
TCN068	CC6.8 CC7.2	A central antivirus server is configured with antivirus software to protect registered production Windows servers and workstations with the following configurations: • Scan for updates to antivirus definitions and update registered clients on a daily basis; • scan registered clients on a weekly basis.	Inquired of management to confirm antivirus software is configured for servers and workstations. Inspected Antivirus Console Screenshot to determine whether it is configured to receive an updated virus signature at least daily. Inspected a sample of workstations to determine whether antivirus is installed and up to date.	No exceptions noted
TCN069	CC6.8	The ability to promote source code, infrastructure changes, and patches to the production environments is restricted to user accounts accessible by authorized personnel by the version control software.	Inspected the documentation to confirm the ability to promote source code, infrastructure changes, and patches to the production environments is restricted to user accounts accessible by authorized personnel by the version control software.	No exceptions noted
TCN070	CC6.8 CC7.2 CC8.1	A file integrity tool is utilized to monitor for changes to the production environment and send notifications to authorized personnel.	Inquired of Management regarding the file integrity tool to determine that a file integrity tool was utilized to monitor for changes to the production environment.	No exceptions noted
TCN071	CC6.8	The ability to modify the file integrity tool is restricted to user accounts accessible by authorized personnel.	Inspected administrator access to the file integrity tool to determine that the ability to modify within the tool was restricted to user accounts accessible by authorized personnel.	No exceptions noted
TCN072	CC7.1	Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches.	Inspected sample security and network logging features are utilized to monitor and analyze the in-scope systems and that track remediation efforts as evaluated by Cloudmed IT.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN073	CC7.3	Management meetings are held on an ad hoc, post-incident basis to discuss incidents and corrective measures to ensure that incidents are resolved.	Inquired of management to determine whether resolution of security events (incidents or problems) is reviewed at the daily and weekly operations and security group meetings.	No exceptions noted
TCN074	CC7.3	Incident Response policy is documented and maintained that address remedial actions for lack of compliance with policies and procedures.	Inspected Incident Response plan to confirm an incident management procedure is in place and that it addresses remedial actions for lack of compliance.	No exceptions noted
TCN075	CC7.3 CC7.4	Cloudmed creates and maintains a complete, accurate and timely record of authorized, and unauthorized, disclosures of personal information.	Inquired of Cloudmed's Privacy team to confirm they create and maintain a complete, accurate and timely record of authorized disclosures of personal information.	No exceptions noted
TCN076	CC7.4 CC7.5	Operations personnel utilize an automated ticketing system to document security violations, responses, and resolution.	Inspected change requests to determine whether they are documented in the system, tickets are assigned, and recurring meetings are maintained to track and complete the process.	No exceptions noted
TCN077	CC7.4	Incidents requiring a change to the system follow the standard change control process.	Inspected a sample of change management requests to determine whether the criteria were addressed.	No exceptions noted
TCN078	CC7.5	Cloudmed has implemented an Incident Response Policy to recover from identified security incidents.	Inspected Cloudmed's Incident Response Policy to determine that procedures to recover from identified security incidents are in place.	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
TCN079	CC8.1	Changes made to in-scope systems are authorized, tested, and approved prior to implementation.	Inspected the in-scope applications and their supporting systems and obtained sample documentation supporting changes. (change tickets) For the change tickets selected, inspected for appropriate testing and approvals were obtained of management. Inspected change tickets to determine whether changes were appropriately tested prior to installation. Inspected a selection of change tickets to determine if the following phases were completed and documented: • Authorization • Development • Testing • Implementation	No exceptions noted
TCN080	CC8.1	For each application, there are separate a production, test/acceptance, and development environments.	Inspected the provided documentation to verify a separate production, test/acceptance, and development environments exist.	No exceptions noted
TCN081	CC8.1	Access privileges to promote changes in the production environment are segregated from those with development responsibility and restricted to user accounts accessible by persons within the IT department. Where such segregation is not practical, management has implemented additional controls.	Inspected system screenshots to verify that access privileges to promote changes in the production environment are segregated from those with development responsibility and restricted to user accounts accessible by persons within the IT department. Inquired of management of additional controls in place to mitigate any potential segregation issues.	No exceptions noted
TCN082	CC8.1	Change requests include Back-out/Recovery Plan describing how a change will be dealt with in the production environment should an issue occur during roll-out or post-implementation.	Inspected a sample of changes to confirm change requests must include Back-out/Recovery Plan describing how a change will be dealt with in the production environment should	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
			an issue occur during roll-out or post-implementation.	
TCN083	CC8.1	Change management policies and procedures are documented that outline that change management separation of duties such that authorization, development, testing, and implementation are segmented functions within the process.	Inquired of management to determine whether Policies are updated on an as-needed basis and an annual review is performed. Inspected the CDP Application Development policy to confirm that authorization, development, testing, and implementation are segmented functions within the process.	No exceptions noted
TCN084	CC8.1	Client data is not utilized for application change control testing.	Inquired of management to confirm that client data is not utilized for application change control testing.	No exceptions noted
TCN085	CC8.1	Changes to a production environment that are deemed "emergencies" may be fast-tracked through a Change Control process upon approval from a Principal or Director of Information Technology. In such cases, a documented change request via the ticketing system must be completed and logged after the emergency is resolved.	Inspected the Information Security Policy to confirm that changes that are deemed "emergencies" may be fast-tracked through the change control process upon approval from a Principal or Director of Information Technology and a documented change request via the ticketing system must be completed and logged immediately after the emergency was resolved. Inquired of management regarding emergency changes to confirm they are rare and follow the established process.	No exceptions noted
TCN086	CC8.1	Source code for in-house developed systems or software is controlled via source code repositories.	Inquired about the code repositories and confirmed that source code for in-house developed systems or software is controls via a source code repository.	No exceptions noted
TCN087	CC9.1	A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance	Inspected the risk management policy to determine that a program had been established around the identification of	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
		of the risks associated with the identified threats, and mitigation strategies for those risks.	potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	
TCN088	CC9.1 CC9.2	The risk management program includes the use of insurance to minimize the financial impact of any loss events.	Inspected insurance policy to determine that the risk management program includes the use of insurance to minimize the financial impact of any loss.	No exceptions noted
TCN089	CC9.2	Signed agreements, including nondisclosure language, are required before sharing information designated as confidential with third parties.	Inspected a sample service agreement to confirm that non-disclosure language was used and agreements are signed before sharing information designated as confidential with third parties.	No exceptions noted
TCN090	CC9.2	Customer contracts, service-level agreements, and vendor contracts are negotiated before performance or receipt of service.	Inquired of management to determine that Customer contracts, service-level agreements, and vendor contracts were negotiated before performance or receipt of service.	No exceptions noted
TCN091	CC9.2	Management reviews documentation provided by third party providers to help ensure that third-party providers are in compliance with security and confidentiality policies.	Inquired of management to obtain an understanding of the management approval process for updates to confidentiality commitments and requirements.	No exceptions noted
TCN092	C1.1 C1.2	Cloudmed has a documented Information Security policy which covers data retention and has processes in place to retain and dispose of information according to the policy.	Inquired of management to obtain an understanding of the data retention policies and procedures. Inspected the documented Information Security policy and data retention information to confirm there is a process in place to retain and dispose of information accordingly.	No exceptions noted
TCN093	C1.1	Upon hire, all employees sign acknowledgment forms for the Information Security Policy and Employee Handbook, which covers non-	Inquired of HR Managers to determine that all new Cloudmed employees sign acknowledgment forms upon hire relating to the Information	No exceptions noted

CONTROL NUMBER	CRITERIA NUMBER	DESCRIPTION OF CLOUDMED'S CONTROLS	SERVICE AUDITOR'S TEST OF CONTROLS	RESULT OF TEST OF CONTROLS
		disclosure, as well as a confidentiality agreement.	Security Policy and Employee Handbook as well as a confidentiality agreement. Inspected a selection of new employees to determine that new Cloudmed employees sign acknowledgment forms upon hire relating to the Information Security Policy, Employee Handbook and a confidentiality agreement.	
TCN094	C1.2	Confidential information is disposed upon termination of the services provided to the customer in accordance with the disposal commitments.	Inspected evidence of the disposal of customer data for a sample of customers that terminated their service during the review period to determine that customer data was disposed upon termination of the services provided to the customer in accordance with the disposal commitments and that the results of the disposal of confidential information were documented and tracked through resolution within the automated ticketing system for each customer sampled.	No exceptions noted

Section 5: Other Information Provided by Management

Management's Response to Noted Exceptions

Prior to COVID, onboarding paperwork was collected in person which allowed HR to quickly identify missing paperwork. The exceptions occurred during the first virtual onboarding during COVID. Further QA and verification of employee forms electronically improved the process and eliminated the gaps. As a result of the merger with Cloudmed, the onboarding paperwork is being processed through an online training and acknowledgement program hosted by Navex Global and coordinated and managed by the HR and Compliance teams for Cloudmed.